Computers & Security 173 (2027) 105216

Contents lists available at ScienceDirect

Computers & Security

journal homepage: www.elsevier.com/locate/cose

Full length article

An open-source-based Information Security Management System for scientific computing: A reference implementation and case study

Jose Ibán Cabrillo Bartolomé, Miguel Ángel Nuñez Vega, Aida Palacio Hoz *

IFCA - CSIC - UC, Instituto de Física de Cantabria, Avda. de los Castros s/n, Santander, 39005, Cantabria, Spain

ARTICLE INFO

Keywords:
Cybersecurity
Security governance
ISO/IEC 27001
Spanish National Security Framework
Open-source
Scientific computing
Information Security Management System

ABSTRACT

Scientific computing centres combine HPC, Grid, Cloud, storage, and federated services, creating heterogeneous environments in which information-security requirements must be translated into operational processes and technical mechanisms. This paper presents an implementation methodology and real-world case study of a predominantly open-source-based Information Security Management System (ISMS) at the Institute of Physics of Cantabria (IFCA). The methodology establishes explicit traceability between key challenges associated with securing research infrastructures, including risk management, access control, data protection, and regulatory compliance.

The reference implementation supports compliance with ISO/IEC 27001:2022 and the Spanish National Security Framework (ENS) through open-source technologies for identity and access management, configuration control, monitoring, log management, vulnerability management, backup, incident handling, documentation, and collaboration. The evaluation combines control coverage, implementation maturity, operational indicators, documentary evidence, and independent audit results. Of the 126 applicable entries in the combined ISO/IEC 27001–ENS control register, 120 had an identified implementation mechanism, resulting in a control coverage of 95.2% and an estimated implementation maturity of 86.7%. Successful certification and subsequent surveillance activities provide independent evidence of conformity within the defined scope.

The case study shows that open-source technologies can support a substantial part of a scientific-computing ISMS, emphasising the importance of integrating security practices into scientific workflows, supporting operational consistency and providing independent evidence of conformity within the defined scope. The proposed methodology, together with the mapping between controls, operational capabilities, and supporting technologies, provides a reference that may be adapted by other research institutions, although further validation in additional computing centres is required.

1. Introduction

Over the past two decades, scientific computing centres have gained immense significance in many different areas. They have become essential infrastructures for modern research based on data-intensive applications, offering shared access to large-scale processing, storage, scientific software and collaboration (Fabre et al., 2021). Moreover, their role has expanded as collaborative projects increasingly depend on distributed data processing, Artificial Intelligence (AI) and Deep Learning (DL), large-scale simulation, and data-exchange between geographically dispersed institutions (Diskin et al., 2021). Consequently, modern scientific data centres no longer operate as isolated high-performance computing facilities, but as heterogeneous environments combining HPC, Grid, Cloud, Federated Authentication and Authorisation Infrastructure (AAI), storage and remotely accessible services (Fecher et al., 2021).

This evolution has increased both the operational value and the security exposure of scientific infrastructures. Many challenges related to the data exchange, remote access, multitenancy, usage of unmaintained applications and federated users enlarge the attack surface and complicate the definition of security policies. Recent reports (IBM, 2026) indicate the influence of a rapid identification and containment of security incidents that can decrease the cost in an institution. For scientific institutions, an incident may affect not only service availability and financial resources, but also the confidentiality, integrity, preservation, and reproducibility of research data.

The growing use of data-intensive techniques introduces additional security and privacy requirements, giving rise to new scientific fields with formidable challenges to address (Guo and Chen, 2023). In specific fields such as medical (Shojaei et al., 2024) or criminology (Mario

* Corresponding author.
E-mail addresses: cabrillo@ifca.es (J.I. Cabrillo Bartolomé), manunez@ifca.es (M.A. Nuñez Vega), aidaph@ifca.es (A. Palacio Hoz).

https://doi.org/10.1016/j.cose.2026.105216
Received 28 April 2026; Received in revised form 17 September 2026; Accepted 15 October 2026
Available online 24 October 2026
0167-4048/© 2026 The Authors. Published by Elsevier Ltd. This is an open access article under the CC BY-NC-ND license (http://creativecommons.org/licenses/by-nc-nd/4.0/).

and Kilty, 2024), the use of personal data demands well-defined access procedures designed to mitigate privacy risks such as role-based authentication and authorisation. In this way, these environments require mechanisms for authentication, authorisation, traceability, data protection, incident management, and service continuity. To address these measures, system administrators have a wide catalogue of software, and this is where open-source software plays a fundamental role (Rodríguez-Mejías et al., 2024).

The adoption of open-source software (OSS) offers several advantages that make it valuable in scientific environments (Pianosi et al., 2020) because it supports transparency, adaptability, interoperability, knowledge sharing, and reproducibility of the scientific research (Lear et al., 2023; Gun and Garg, 2024; Antunes and Hill, 2024). It can also reduce dependence on proprietary licensing models and allow institutions to adapt individual components to their operational requirements. However, an open-source-based security architecture is not cost-free or automatically secure. It requires specialised knowledge, integration between independently developed components, continuous vulnerability management, lifecycle monitoring, configuration control, and procedures for collecting evidence of control effectiveness.

In recent years, data centres, governments, and supranational organisations have introduced numerous security initiatives, including Information Technology Infrastructure Library (ITIL), Control Objectives for Information and related Technology (COBIT), Network and Information Security Directive (NIS/NIS2), ISO/IEC 9001, IEC/ISO 27000 family, and National Security Frameworks (NSFs) such as the Spanish NSF — called *Esquema Nacional de Seguridad (ENS)*. Information Security Management Systems (ISMSs), particularly those based on ISO/IEC 27001, provide a systematic approach for managing the security and operational requirements through risk assessment, security controls, documented processes, assigned responsibilities, retained evidence, and continual improvement (Podrecca et al., 2022). Nevertheless, these standards primarily define the security objectives and controls that must be addressed; they do not prescribe the concrete technologies, integration mechanisms, or operational evidence that should be used in a heterogeneous scientific computing infrastructure.

Previous studies have examined ISO/IEC 27001 adoption in public organisations, data centres, small and medium-sized enterprises (SMEs), and scientific infrastructures. Related research has also addressed mappings between security standards, requirements-engineering methods for ISMS implementation, and the organisation of Security Operations Centres (SOCs). However, limited implementation-oriented guidance is available on how to translate security controls into operational capabilities, documented processes, selected technologies, assigned responsibilities, and auditable evidence within a heterogeneous scientific computing service.

This work addresses this gap by proposing a reproducible control-to-capability-to-process-to-tool implementation methodology for an open-source-based ISMS. The methodology is evaluated at the Institute of Physics of Cantabria (IFCA), whose computing infrastructure combines HPC, Grid, cloud, storage, and federated scientific services. The case study is evaluated through control coverage, operational evidence, implementation experience, and external ISO/IEC 27001 and ENS certification within the defined scope.

This work focuses on the following aspects, crucial to ensure the security in scientific environments:

- Description of the security challenges found based on our scientific computing experience and how can be aligned with the ISMS implementation
- Adoption plan for implementing a security standard in a scientific computing environment
- Methodology followed for risk-control-process-tool-evidence mapping
- Information Security Management standards implementation in a real-world case study
- The efficient and affordable use of open-source software to build a scientific computing service. This aligned with some of the scientific security challenges and the establishment of security certification in a computing service
- Evaluation and lessons learned by the implementation

This document is structured as follows. Section 2 provides a background review of the state of the art and related works in the field. Subsequently, Section 3 explains the methodology followed to adapt an ISMS implementation to security-standard procedures. Section 4 presents the ISMS implementation at a real-world case study aligning the security control metrics of the ISO/IEC 27001 and ENS with the use of open-source technologies. The evaluation and discussion is described in Section 5 with the consequent challenges and future direction of this work in Section 6. Finally, the document concludes in Section 7 and open debates within the scientific security community.

2. Background and related work

Over time, some data processing centres transitioned to hybrid computing models, known as Elastic Clusters (Mateescu et al., 2011), to meet the evolving needs of researchers. In these models, the integration of cloud computing into data centres completely transformed the system management architecture, which was traditionally based on HPC or HTC. This evolution resulted in the coexistence and convergence of three paradigms: traditional HPC, Grid, and cloud computing (Giordano et al., 2021), prompting data centres to modernise and adapt to more dynamic and flexible technologies.

While private cloud computing services from providers like AWS, Azure, Google and Oracle offer scalable solutions, the cost of implementing services for computational workloads, massive data transfers, and storage requirements in the range of 10^2 TB or even PB is prohibitive for many institutions. As a result, most scientific centres have opted to deploy their own cloud services using open-source solutions like OpenStack Project (2026) and OpenNebula (2026), or Apache CloudStack (2026).

The adoption of open-source tools has become a cornerstone of innovation in scientific projects due to their flexibility, cost-effectiveness, and adaptability (Tsipouri et al., 2025). Recent studies have highlighted the role of open-source software in improving transparency, reuse, distributed collaboration, and computational reproducibility. Open licensing enables researchers to inspect, modify, and redistribute software, although effective reuse also depends on documentation, testing, maintenance, and appropriate software-engineering practices (Barba, 2022). Recent evidence further suggests that maintained scientific open-source projects can achieve substantial longevity, although their sustainability still depends on governance, contributors, institutional support, and lifecycle management (Thakur et al., 2025).

The project CERN's White Rabbit (Pujol Priego and Wareham, 2023) carried out by CERN collaboration reflects how open-source software can fulfil the requirements of scientific communities. This work demonstrates that the development of hybrid digital objects (hardware and software) can be effectively achieved through open-source methods.

The increasing professionalisation and interconnection of scientific data centres has strengthened the need for systematic information security governance. Standards such as ISO/IEC 27000 family provide a risk-based framework for establishing, operating, reviewing, and continuously improving the ISMS. In addition, NSFs establish extra requirements and security measures for information systems.

To address these needs, computing services require specialised software and procedures to protect the organisation's assets and build a robust SOC to be aligned with the ISMS. For example, the article by Vielberth et al. (2020) presents a comprehensive study on the main challenges and current state of SOCs. It emphasises that security encompasses various levels, including infrastructure, access control (both logical and physical), configuration management, vulnerability

management, privacy, and regulatory compliance. These areas must be consistently addressed to ensure quality standards for clients as defined in Service Level Agreements (SLAs).

The adoption of cybersecurity standards not only enhances the reliability of scientific computing centre but also fosters trust among clients by demonstrating compliance with internationally recognised security and quality practices. Establishing and maintaining a SOC is essential for ensuring proactive prevention and implementing centralised security strategies. However, this process can be costly, particularly when clear guidelines, policies, and procedures are not rigorously followed. Moreover, many proposed solutions rely on proprietary software, which can lead to high costs and vendor lock-in, reducing flexibility for future technological adaptations. Based on our experience, these challenges can be effectively addressed through the implementation of open-source technologies, which offer cost-efficiency and adaptability.

Regarding related work, several studies have analysed the implementation of information security standards in different organisational contexts. These contributions can generally be divided into standard-mapping studies, implementation roadmaps, procedural models, and sector-specific case studies. However, many of them focus primarily on interpreting the standard, defining implementation stages, or identifying organisational requirements, while providing limited detail on how security controls are operationalised through integrated technologies and audit evidence.

Haufe et al. (2016) compare information security management standards and identify common processes and relationships between their requirements . Similarly, Rajak et al. (2023) present a step-by-step roadmap for ISO/IEC 27001 implementation based on the Plan–Do–Check–Act cycle. Their approach covers the definition of the ISMS scope, gap analysis, asset inventory, risk assessment, the Statement of Applicability, policies, procedures, internal auditing, and continual improvement. Moses and Sandkuhl address ISMS adoption in small public-sector organisations by combining the requirements of the NIS 2 Directive (European Union, 2026) with barriers and critical success factors identified through a structured literature review (Moses and Sandkuhl, 2023). Following a Design Science Research approach, they derive a procedural model intended to facilitate ISMS implementation in organisations with limited personnel, financial resources, and security expertise.

Other works report sector-specific implementation experiences. ISO/IEC 27001 adoption has been studied in public organisations (Sussy et al., 2015), financial institutions (Hasibovic and Tanovic, 2024), and small and medium-sized enterprises (Mera-Amores and Roa, 2024). Related approaches have also combined NIST SP 800–53, the NIST Cybersecurity Framework, and other control catalogues for cyber-risk management planning (Amiruddin et al., 2021).

Among the most closely related scientific-computing experiences, Chierici et al. describe the implementation of an ISO/IEC 27001 ISMS at the INFN-CNAF data centre (Chierici et al., 2019). Their work demonstrates the feasibility of applying formal security management practices within a large research infrastructure and discusses the adaptations required to support projects with sensitive-data requirements. Nevertheless, it does not provide a general taxonomy of operational capabilities, a detailed control-to-tool mapping, or a comparative analysis of the components that can support the complete ISMS lifecycle. Existing research can therefore be grouped into three complementary areas: methods for interpreting and implementing security standards; sector-specific ISMS case studies; and studies of SOC architectures and operational security technologies. However, these areas are commonly addressed separately. This work addresses this gap through a reproducible implementation methodology for a predominantly open-source ISMS in a heterogeneous scientific computing environment.

The proposed methodology establishes explicit traceability between identified risks, applicable ISO/IEC 27001–27002 and Spanish NSF — *Esquema Nacional Seguridad* (ENS) — controls, operational processes, security capabilities, supporting tools, responsible roles, and retained evidence. The solution is presented as a real-world reference implementation and is evaluated using implementation coverage, operational evidence, external certification results, limitations, and lessons learned.

3. Methodology

This study follows an implementation-oriented case-study approach. Its purpose is to define and apply a reproducible methodology for translating information-security requirements into organisational processes, operational capabilities, supporting technologies, responsible roles, and auditable evidence. The Institute of Physics of Cantabria (IFCA) computing service is used as the case-study environment and as the reference implementation of the proposed methodology.

3.1. Case-study scope

The Institute of Physics of Cantabria (IFCA), is a joint centre of the Spanish National Research Council (CSIC for *Consejo Superior de Investigaciones Cientificas* in Spanish) and the University of Cantabria (UC), operates a medium-sized data centre focused on research fields such as astrophysics, matter structure, and artificial intelligence. To support these endeavours, the IFCA employs an elastic computing model based on HPC, GRID, and Cloud systems. This data centre not only provides services to local scientific users but also integrates into broader e-infrastructures and federated computing initiatives, such as the European Grid Initiative (EGI, 2026) evolving towards a Federated Cloud, the (Worldwide LHC Computing Grid (WLCG), 2026), and supports projects under the European Open Science Cloud (EOSC, 2026) framework and the Intergovernmental Panel on Climate Change (IPCC, 2023). Consequently, the IFCA data centre and its computing services exemplify a scientific computing data centre paradigm.

The unit of analysis is the IFCA computing service covered by the ISMS. The scope includes the HPC, Grid, Cloud, storage, authentication, and supporting operational services managed by the computing team, together with the physical resources, technical components, personnel roles, and organisational dependencies required for their provision. Systems and applications independently managed by research groups are excluded unless they depend directly on services included in the ISMS scope.

The case study examines the implementation and operation of the ISMS from its initial certification process to the subsequent surveillance and renewal activities. The analysis is based on the Statement of Applicability, risk-treatment plan, asset inventory, documented procedures, operational records, control tests, and internal and external audit results. ISO/IEC 27001 and ISO/IEC 27002 constitute the international security-management baseline, while the ENS provides the applicable national requirements. Furthermore, this implementation leverages IFCA's pre-existing ISO 9001 (International Organization for Standardization, 2015) quality management framework, extending its management procedures to the security governance of the computing service.

3.2. Requirements elicitation

The methodology was derived from the security and operational challenges identified during the management of the IFCA computing infrastructure. These challenges are not limited to conventional infrastructure protection, since scientific computing environments must also support rapidly changing software, external collaborations, sensitive data, and reproducible research workflows. The following items summarise the main challenges and the methodological requirements derived from them.

1. Lack of cybersecurity culture
    - Organisational security knowledge
    - Awareness and training activities
    - Incident-reporting mechanisms
    - Periodic compliance reviews
2. Software maintenance and vulnerability management

- Asset and software inventory
- Patch and vulnerability management
- Change and exception management
- Risk-acceptance procedures

3. Governance and lifecycle of open-source software installation

- Software-selection criteria
- Authorised installation procedures
- Dependency and provenance tracking
- Maintenance and vulnerability reviews
- Component-replacement criteria

4. Sensitive data and privacy

- Secure data storage
- Risk-based access control
- Authentication and authorisation procedures
- Encryption, logging, and retention mechanisms

5. Quality assurance of scientific software

- Version control and peer review
- Automated testing
- Controlled deployment
- Documented validation procedures

6. Data and software reproducibility

- Preservation of software versions, configurations, and dependencies
- Data provenance and execution metadata
- Integrity records
- Procedures for recreating computational environments

These observations were translated into design requirements for the ISMS. In particular, the implementation had to provide common governance across heterogeneous services and the appropriate process and tools to comply all these requirements from personnel and user training to systematic evidence collection.

3.3. Normative baseline

The certification process, while highly beneficial, can become lengthy and complex, particularly in its initial phases, when a significant volume of information and documentation is generated. It is crucial to remember that the ultimate goal of certification is to provide an objective guarantee that the ISMS, security measures, and organisational practices comply with standard requirements, transforming it into a continuous improvement process. This approach drives incremental advancements over time, systematically evaluated through regular assessments.

The proposed methodology uses ISO/IEC 27001:2022 and ISO/IEC 27002:2022 (International Organization for Standardization and International Electrotechnical Commission, 2022) as its international information-security management baseline, together with the Spanish National Security Framework (ENS), regulated by Royal Decree 311/2022 (Government of Spain, 2022). ISO/IEC 27001 specifies the requirements for establishing, operating, evaluating, and continually improving an ISMS, whereas ISO/IEC 27002 provides guidance for implementing the associated information-security controls. The relationships between ISO guide controls and ENS security measures were established using the official CCN-STIC 825 mapping as a Ref. Centro Criptológico Nacional (2023).

The ISO/IEC 27000 family of standards has long been recognised as foundational standards for cybersecurity. However, the evolving regulatory landscape may require compliance with additional certifications such as National Security Frameworks (NSFs) (Rodríguez-Mejías et al., 2024) and the newly introduced NIS2 directive (the successor to the NIS directive).

Annex A of ISO/IEC 27001:2022 contains 93 controls aligned with the guidance provided by ISO/IEC 27002:2022 and grouped into four domains. In its latest 2022 version restructures the controls into four major sections instead of the 14 domains of previous version (2017).

1. **Organisational controls**: 37 controls. These are focused on the management and governance of information security within the organisation. This category includes: information security policies, security roles and responsibilities, risk management, information classification and handling, supplier and third-party relationship management, access and privilege management, security awareness and training, business continuity and cybersecurity.
2. **People Controls**: 8 controls. These manage human-related risks within the organisation, such as personnel background checks, employee and third-party lifecycle management, cybersecurity awareness, disciplinary policies and responsibilities.
3. **Physical Controls**: 14 controls. These protect physical assets and access to information in business environments. This includes: facility security, physical access control, protection against natural disasters, equipment management and secure disposal of assets.
4. **Technological Controls**: 34 controls. These address the protection of the organisation's technological infrastructure, including: access management and authentication, encryption and data protection, network and communication security, protection against malware and threats, vulnerability and update management, security monitoring and incident response.

Those metrics apply to the scope of the service to be certified, which in this case has been the IFCA computing service. The process of satisfying the controls of the certification guide is an arduous and complex task, where we must individually analyse the software used by the organisation and establish whether it meets the needs established in the control, and if not, seek an alternative.

These standards facilitate the alignment of available resources to meet the certification requirements, ensuring a systematic approach to compliance. Addressing all points of the standard within the scope is essential for any computing service to establish an ISMS capable of safeguarding the hosted information effectively.

The ENS (National Security Scheme) and ISO/IEC 27001 share a common approach to information security, particularly in areas such as risk management, security controls, incident management, and continuous improvement. Nevertheless, they differ in scope and regulatory status. ISO/IEC 27001 is an international and certifiable standard that defines the requirements for establishing and maintaining an Information Security Management System (ISMS) and can be applied to organisations across different sectors. In contrast, the ENS is a Spanish regulatory framework that establishes mandatory security requirements for public sector organisations, systems, and, under certain conditions, their suppliers. The ENS also defines specific security measures according to three system categorisation levels: basic, medium, and high.

These levels are determined based on the potential impact a security incident could have on protected assets, such as information, systems, or services. The severity of the security measures that an entity will adopt will depend on the sensitivity of the information handled and the potential negative impact that could result from a breach of data confidentiality, integrity, or availability. This implementation therefore uses the risk assessment, legal and contractual requirements, and available ISO/IEC 27001 and ENS mappings to determine control applicability.

The ISO/IEC 27001 and the ENS share a common objective of establishing and maintaining robust information security measures to

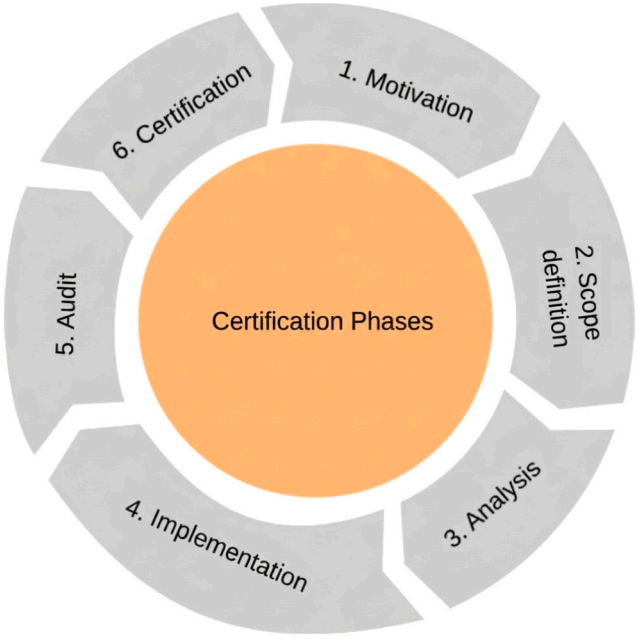


Fig. 1. ISMS implementation and continual-improvement lifecycle followed in the IFCA case study.

safeguard organisational assets. Both frameworks emphasise the importance of identifying, assessing, and treating risks that may affect information security and promote a proactive approach to security management, with a continuous improvement cycle through evaluation, risk treatment, and periodic review of security controls.

3.4. ISMS lifecycle

An Information Security Management System (ISMS) is responsible for defining processes and policies, assessing weaknesses and threats, and ensuring the integrity and confidentiality of all assets involved in the system, whether they are physical or virtual. The ISMS must evaluate all risks associated with the information system within the service scope, establishing actions to mitigate manageable risks and accepting the remaining ones.

Implementing an ISMS requires the participation of all organisation members, not just the computing service team, making information security a central component of any institutional activity. To achieve this goal, an effective inventory management process is essential, enabling the identification of risks and evaluation of threats. Through well-defined policies, procedures, controls, and response protocols, the impact and response time to incidents can be minimised, reducing the severity of threats and ensuring business continuity. Consequently, an ISMS must be flexible, allowing additional software or modification of tools as necessary. Furthermore, the ISMS mandates compliance with current security regulations, incorporating both national and international laws governing data processing and protection, and ensuring their enforcement at all levels within the service scope.

In the process of bringing the computing service into compliance with the ISO/IEC 27001 and ENS, both service and organisation must undergo a series of steps depicted in Fig. 1. The proposed methodology is structured as an iterative ISMS lifecycle that connects the personnel experience, risk management, control implementation, operational evidence, and continual improvement.

The lifecycle begins with the identification of the internal and external motivations for implementing an ISMS and the definition of its scope. Internally, the objective is to organise the service, assign responsibilities, formalise operational procedures, and establish policies and procedures to mitigate risks faced by data centres in daily operations. Externally, certification provides independent recognition of the institution's security practices and strengthens trust among users, collaborators, and funding bodies. These measures ensure resilience against threats while preserving operational integrity. Such certifications validate the institution's commitment to security excellence, fostering trust and credibility within the global community. Balancing internal operational robustness with external validation highlights the importance of a holistic approach to security management.

Once the scope has been defined, the organisation performs a baseline assessment of its initial security and management situation. This assessment identifies existing policies and controls, undocumented operational knowledge, dependencies on specific personnel, obsolete or insufficiently reviewed systems, abandoned developments, available resources, and the recurring effort required to maintain the ISMS. In addition, a SWOT analysis is used at this stage to examine the internal strengths and weaknesses of the computing service and the external opportunities and threats affecting it. Therefore, the SWOT analysis supports the definition of the organisational context and implementation priorities, supported by the subsequent formal information-security risk assessment.

Risk management then identifies the information assets, supporting services, asset owners and dependencies within the defined scope. Risks are evaluated according to their likelihood and potential impact, and a treatment decision is established for each of them through mitigation, avoidance, transfer, or acceptance. The resulting risk-treatment plan determines the applicable security controls and the residual risks that require formal acceptance.

This decision is formally documented in the Statement of Applicability (SoA). For each ISO/IEC 27001 control, the SoA records its applicability, the justification for its inclusion or exclusion, its implementation status, and its relationship with the identified risks and requirements. The SoA therefore provides the formal connection between risk management and control implementation.

In the implementation stage, these controls are subsequently translated into operational capabilities defined in the proposed ISMS taxonomy: organisational processes, documented procedures, operational capabilities, responsible roles, technical mechanisms, and auditable evidence. Open-source technologies are selected according to their functionality, usability, interoperability, maintainability, security, and ability to support the required processes and generate evidence of control operation.

Then, the control-mapping process follows the relationship:

Risk → Control → Process → Capability
→ Responsible role → Tool → Audit evidence
→ Effectiveness indicator

In practice, this mapping is applied as an operational workflow using defined procedures and tools. The asset inventory, service catalogue, risk assessment, SoA, certification procedures, and existing technologies provide the inputs for each control implementation. The certification follows provided templates to complete the risk assessment, SoA and the certification procedures. For each applicable control, the implementation team identifies the corresponding process, capability, responsible role, supporting mechanism or tool, retained evidence, and indicator used to assess its operation. The resulting evidence includes configuration records, monitoring data, access reviews, vulnerability records, incident tickets, backup reports, restoration tests, change records, and corrective-action records generated during normal service management.

This operational workflow ensures that a control can be followed from its originating risk or requirement to the evidence used during operation and auditing. For example, the management of technical vulnerabilities is triggered by the risk of unpatched systems, the vulnerability-management process, the monitoring and protection

capability, the system-administrator role, and supporting tools such as Wazuh, Security Onion, Puppet, and Request Tracker. The retained evidence includes vulnerability findings, security advisories, patching records, tickets, and closure information, while effectiveness is assessed through remediation-time indicators and the percentage of high- and critical-severity vulnerabilities remediated within the defined target period.

After implementation, the effectiveness of the controls is assessed through metrics such as traceability completeness (SoA, SWOT and risk-treatment), control coverage and implementation maturity, operational effectiveness and maintainability (access reviews, vulnerability-management records, incident tickets, monitoring information, backup reports, restoration tests) and external conformity. Internal and external audits identify non-conformities, observations, and opportunities for improvement, which are documented and addressed through corrective actions. Certification is granted when the external certification body verifies that the ISMS satisfies the applicable requirements within its defined scope.

Nevertheless, certification does not conclude the lifecycle. Changes in services, assets, personnel, threats, technologies, or regulatory requirements may introduce new risks and require the revision of controls, procedures, tools, and evidence. Audit findings and operational results are therefore fed back into the risk-management process, supporting continual improvement of the ISMS.

4. ISMS implementation

The adoption of open-source software (OSS) in critical environments offers significant advantages in terms of transparency, auditability, cost optimisation, and adaptability to regulatory frameworks such as ISO/IEC 27001 and ENS. However, its use also introduces risks that require appropriate management, including exposure to zero-day vulnerabilities (e.g., CVE-2026-31431) and supply-chain compromises (e.g., the XZ Utils incident). These risks highlight the need for continuous monitoring and appropriate governance of software components, dependencies, and provenance.

In this work, OSS was incorporated into the ISMS through a four-step process comprising risk-based selection criteria, initial and residual software risk assessment, operational fit, and lifecycle governance. The approach was applied to the software supporting the operational capabilities of the IFCA infrastructure and is described in the following sections.

Table 1 summarises the technologies selected for the IFCA implementation and their corresponding operational capabilities. It also includes the risk assessment, audit evidence required to support the certification process, and examples of maintained open-source alternatives.

4.1. Open-source software risk management and governance

Software selection was linked to the ISMS risk management process through five dimensions: security, lifecycle, dependencies, provenance, and licensing. These dimensions cover the main risks considered when introducing and maintaining software components in the IFCA infrastructure.

The security dimension considers known vulnerabilities, security advisories, exploitability, patch availability, and the ability to deploy security updates. The lifecycle dimension considers project maturity, maintenance activity, supported versions, end-of-life information, and the availability of operational expertise. The dependencies dimension includes direct and transitive dependencies, their visibility and maintenance status, and the risks introduced by external components. Provenance covers the verification of software origin, version, integrity, and distribution through trusted repositories, signatures, hashes, release records, or, where available, Software Bills of Materials (SBOMs). The licensing dimension considers the applicable licence, its compatibility with the intended use, and the associated compliance requirements.

Each dimension was assessed using a 5 × 5 probability-impact matrix. Probability (P) and impact (I) were assigned values from 1 to 5 according to the organisation's risk-assessment procedure. The risk for each dimension was calculated as:

$$R_d = P_d \times I_d, \tag{1}$$

where d denotes the dimension under assessment. Risk scores range from 1 to 25 and were classified as low (1–4), medium (5–9), high (10–16), or critical (17–25).

Initial and residual risks were assessed for each software component. Initial risk represents the risk before applying the additional ISMS measures considered in the assessment, whereas residual risk represents the risk remaining after the selected controls, procedures, monitoring mechanisms, and other mitigation measures have been implemented.

The overall software risk was defined using the highest value among the five dimensions:

$$R_{\text{software}} = \max(R_{\text{sec}}, R_{\text{lif}}, R_{\text{dep}}, R_{\text{prov}}, R_{\text{lic}}). \tag{2}$$

This approach prevents a high risk in one dimension from being offset by lower values in the others. For example, a component with an established project lifecycle and an appropriate licence may still present a high overall risk if a relevant vulnerability cannot be adequately mitigated or its provenance cannot be verified.

Risk treatment depends on the resulting risk level. Low and medium risks can be accepted within the organisation's risk tolerance. High risks require mitigation and subsequent residual-risk assessment, while critical risks prevent production deployment unless the risk is reduced to an acceptable level or an alternative component is selected. Depending on the component, mitigation measures include vulnerability monitoring, patch management, trusted repositories, version and configuration management, access restrictions, centralised logging, backup and restoration procedures, documented operational procedures, assigned ownership, and periodic review.

For candidates with an acceptable residual risk, the selection is based on operational fit. This criterion reflects the suitability of a technology for the specific infrastructure in which it will be deployed. Considered factors include compatibility with existing services, integration and interoperability requirements, deployment and maintenance effort, and the technical resources available for its operation.

Operational fit is therefore context-dependent and does not imply that the selected technology is generally superior to the alternatives. A different organisation applying the same methodology may select another component if its infrastructure or operational constraints lead to a different result. In the IFCA implementation, the selected technologies reflect the requirements and conditions of the target environment.

After selection, each component was incorporated into the ISMS governance cycle and associated with an operational capability, responsible role, applicable controls, and the evidence required for its operation. OSS governance includes maintaining the software inventory, monitoring vulnerabilities and security advisories, reviewing project maintenance status, documenting configuration and deployment changes, and retaining information on licensing and provenance. Replacement criteria are considered for components that become unsupported, insecure, incompatible, or otherwise unsuitable for the ISMS scope.

Thus, OSS is treated as an implementation option rather than as an inherent security or compliance property. Its use within the ISMS is subject to risk assessment, appropriate controls, operational monitoring, evidence collection, and periodic review.

Table 1
Operational ISMS capabilities and supporting technologies selected for the predominantly open-source-based IFCA reference implementation.

Operational capability	Selected technologies	Audit evidence	Operational fit	Initial risk	Residual risk	Alternatives
Authentication and Authorisation Infrastructure (AAI)	FreeIPA (2026)/Keycloak (2026)	Account records; group and role assignments; RBAC policies	Project maturity, Long-term operational experience/Usability, community support	High (R = 15)	Medium (R = 9)	Authelia, Authentik, Casdoor
Backup management	Bacula (2026)	Backup-job monitoring; failure reports; restoration-test results	Project maturity, Long-term operational experience	High (R = 12)	Medium (R = 8)	Duplicati, FreeFileSync
Cluster deployment/Machine provisioning (Physical or virtual)	MAAS (2026)/OpenTofu (2026)	Asset inventory; provisioning logs; operating-system deployment records	Usability, interoperability and integration capabilities	High (R = 12)	Medium (R = 8)	Cobbler, Foreman
Configuration management	Gerrit (2026), Jenkins (2026) and Puppet (2026)/Ansible (2026)	Shared configurations; review approvals; deployment records; configuration reports	Project maturity, Long-term operational experience/Usability	High (R = 15)	Medium (R = 9)	Check Infra, SaltStack
Document management	Outline (2026)	Internal procedures; revision history; SLAs, guidelines	Community support, integration capabilities (OAuth 2.0, Markdown)	Medium (R = 9)	Medium (R = 5)	BookStack, Docmost, XWiki, Docusaurus
File-sharing repository	Nextcloud (2026)	Certification procedures and documents (SWOT, SoA, policies, etc.); file versions and access records	Project maturity, community support	High (R = 12)	Medium (R = 8)	Filestash, Hoodik, ownCloud, Seafile
Log management	Grafana Loki (2026)	Centralised logs; retention records; queries; exported event evidence	Interoperability	High (R = 12)	Medium (R = 9)	Fluent-bit, Fluentd, Graylog, Logstash, SigNoz
Messaging	Mattermost (2026)/Zimbra (2026)	Communication records; message and administrative retained logs	Community support, usability/Long-term operational experience, external support	Medium (R = 9)	Medium (R = 5)	Matrix, Zulip
Monitoring	Grafana (2026) and Icinga (2026)	Alerts; availability history; acknowledgement records	Interoperability, Usability	High (R = 12)	Medium (R = 7)	Nagios, OpenSearch, Zabbix
Protection systems	Cisco Umbrella (2026)/ipset; iptables; MAT2 (2026) and Nwipe (2026)/ Security Onion (2024) and Wazuh (2026)	DNS filtering logs; firewall rule revisions; security alerts; vulnerability findings; secure-erasure records; metadata information	Institutional service/Project maturity, Long-term operational experience/Usability	High (R = 16)	Medium (R = 9)	Snort, Suricata, Zeek
Project management	GitLab (2026); Nextcloud Deck	Issues; milestones; assigned responsibilities; approvals; corrective action records	Project maturity, usability	High (R = 12)	Medium (R = 8)	KanBoard, Leantime, OpenProject, Wekan
Ticketing support	Request Tracker (2026)	Incident and service tickets; maintenance-activity record; role assignment; resolution and closure records	Long-term operational experience	Medium (R = 9)	Medium (R = 5)	GLPI, osTicket
Videoconferencing	Nextcloud Talk	Training and coordination records; attendance or meeting evidence when retained	Usability, interoperability	Medium (R = 9)	Medium (R = 5)	BigBlueButton, Jitsi

Zimbra and Cisco Umbrella are proprietary services provided to IFCA by RedIRIS
Mapping between each technology and the specific ISO/IEC 27001:2022 and ENS controls is maintained in the SoA and summarised in Table 2. Table 1 lists the technologies by operational capability; Table 2 provides representative control-to-tool mappings.

4.2. Architecture

The ISMS implementation process can be complex but following well-defined certification guidelines can reduce the difficulty of this task. Although in some cases the computing infrastructure is already built, the requirements for an ISMS are not reached and these guidelines can help to meet the security requirements. In this regard, this issue is addressed in Step 4 of the ISO/IEC 27001 cycle (1).

Based on the experience of the IFCA IT Team, two main technical actor classes are represented within an ISMS: system administrators and regular users. System administrators are responsible for ensuring the proper functioning of elements within a computing service, while regular users interact with the provided tools within the scope of their authorisation rules. Consequently, the applicable standard controls differ for each role.

In general, administrators are subject to a larger number of policies and controls and interact with a greater variety of software. The technologies utilised by IFCA are organised by their system purposes. These technologies correspond to elements interacting with one or both roles which are essential for the correct implementation of the ISMS. As part of an ISMS, a SOC is the operational component which ensures that security policies are not only documented but also effective in protecting against threats and vulnerabilities. The overall architecture

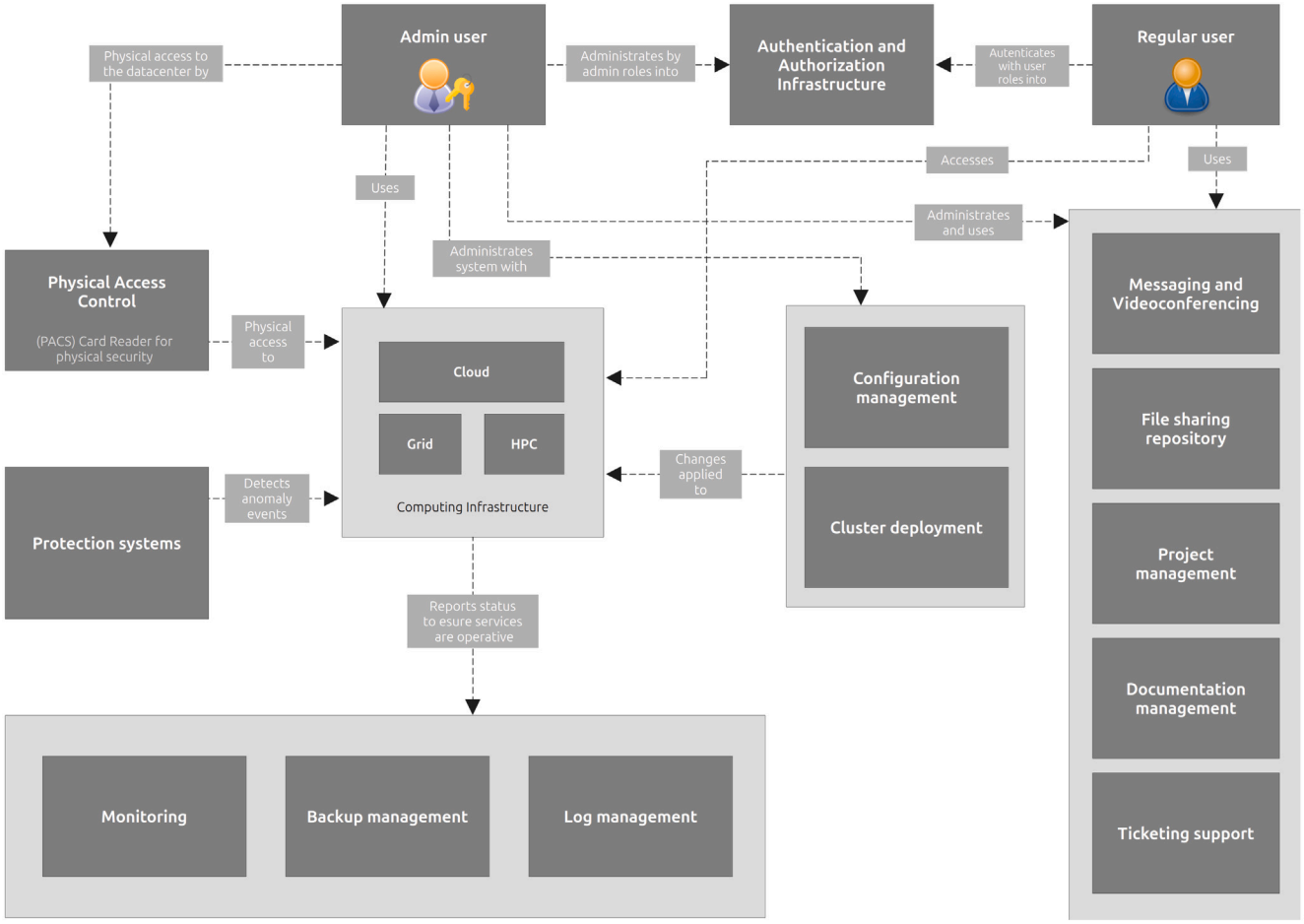


Fig. 2. Container-model representation of the IFCA ISMS architecture, the supporting technologies and the relationship between the operational capabilities.

of the ISMS at IFCA is depicted in Fig. 2 as a container view where the two primary roles interact with the tools selected.

The diagram clusters various technologies with distinct purposes to enhance readability. At its core lies the infrastructure, which supports both the installation of these tools and the operation of computational environments for regular users. Surrounding this core, documentation management and file-sharing tools play a pivotal role within the certification framework, these tools are indispensable for storing documents, procedures, and policies required for compliance with security standards. Beyond document and file management, additional tools such as messaging or videoconferencing are also used by the administrators for day-to-day communication and by regular users to facilitate information exchange within project contexts. Ticketing support and project management systems are crucial for both administrators and users, enabling the registration of security incidents and tracking system changes. For enhanced physical and service security, the implementation of physical access control to data centre room, alongside firewalls and intrusion detection systems, ensures the detection of unauthorised access.

Authentication and Authorisation Infrastructure (AAI) management tools are in direct contact with the admin and users, providing role-based access control (RBAC) for every service within the system. User registration in the AAI service is the first step before accessing the system. Enhancing authentication security is a key priority, AAI tools provide additional functionalities to handle Multi-Factor Authentication (MFA), enabling the use of six-digit codes in addition to conventional username-password authentication.

For effective cluster deployment and maintenance of the entire system, an inventory of the services provided by the configuration management is also mandatory. These tools assist administrators in configuring and deploying the entire system efficiently. Additionally, operational control and security monitoring tools play a crucial role in handling system changes. Log management tools, firewalls, SIEMs and Intrusion Detection Systems facilitate diagnostics, anomaly detection and system protection. In the event of system failures, a robust backup management system supports data recovery and service restoration.

Most (90%) applications within IFCA's ISMS operate in virtualized environments, providing a flexible foundation for on-demand system provisioning. This agility is crucial for evaluating and adopting new security tools to meet the evolving demands of the standard. By leveraging virtualization, systems can be deployed and scaled swiftly to address dynamic requirements. The AAI system, monitoring service and firewalls are the sole exceptions, as they require continuous operation to support administrative tasks and infrastructure status checks.

4.3. Tool-to-control mapping

The SoA and the risk-treatment plan define the controls that must be implemented within the ISMS scope. These controls are subsequently mapped to the operational capabilities and supporting technologies deployed at IFCA. The purpose of this mapping is to show how organisational procedures, assigned responsibilities, technical mechanisms, and audit evidence jointly support its implementation. Consequently, one technology may contribute to several controls, while a single control may depend on multiple tools and organisational measures. Table 2 summarises some examples of the SoA entries, where relationships between the operational ISMS capabilities, the selected technologies, and the controls they support are shown.

Table 2
Examples of representative mappings between controls and supporting technologies to satisfy the ISO/IEC 27001:2022 and the ENS controls grouped by domain (CCN-STIC-825). The complete mapping is maintained as part of the IFCA SoA and control register; non-sensitive entries are reported here.

Reference ISO/IEC 27001	Reference Spanish NSF (ENS)	ISO 27001:2022 control	Tool
5 - organisational controls			
5.1	[org.1] [org.2]	Policies for information security	Outline Nextcloud
5.7	[op.mon.3]	Threat intelligence	Grafana Wazuh
5.8	[op.pl.3]	Information security in project management	Nextcloud Deck
5.15	[op.acc.1]	Access Control	FreeIPA Keycloak
5.16	[op.acc.1]	Identity management	FreeIPA Keycloak
5.24	[op.ext.7]	Planning and preparation for incident management	Request Tracker Wazuh
5.26	[op.ext.7]	Information security incident response	Request Tracker Wazuh Security Onion
6 - People controls			
6.7	[org.2] [mp.per.2]	Remote working	Nextcloud Talk Mattermost Outline
6.8	[op.exp.7]	Information security event reporting	RT Nextcloud Deck
7 - Physical controls			
7.10	[mp.si.1] [mp.si.2] [mp.si.3] [mp.si.4] [mp.si.5]	Storage media	Outline Nwipe
7.13	[op.exp.4]	Equipment maintenance	Grafana Icinga
8 - Technological controls			
8.7	[op.exp.4]	Malware Protection	Wazuh Security Onion
8.8	[op.mon.3] [op.exp.4]	Management of technical vulnerabilities	Gerrit Wazuh Puppet Security Onion
8.13	[mp.info.6]	Information backup	Bacula
8.15	[op.mon.1]	Event register	Grafana Loki
8.16	[op.mon.3] [mp.s.4]	Monitoring activities	Cisco Umbrella Security Onion Wazuh
8.17	[op.mon.2]	Time sync	NTP RedIRIS
8.19	[op.exp.2] [op.acc.3] [mp.sw.2]	Installation of software on operational systems	MAAS OpenTofu Ansible Puppet Nextcloud Deck

In this regard, some open-source tools are not explicitly included within the STIC guidelines of the ENS but have functionality comparable to others and to facilitate future certifications, it would be advisable to establish an official procedure that allows validating open-source tools within the ENS framework, thus ensuring their acceptance in security audits.

5. Evaluation and discussion

5.1. Evaluation strategy

The evaluation of an ISMS should not rely exclusively on the outcome of a certification audit. It should also consider whether the implemented controls can be operated, maintained, reviewed, and adapted by the organisation. From an operational perspective, relevant factors include the clarity of the documentation, the automation of recurring activities, the integration between tools, the traceability of actions, and the effort required by administrators and users to follow the defined procedures.

The proposed methodology is evaluated through an implementation-oriented real-world case study. The purpose of the evaluation is to determine whether the methodology provides a sufficiently complete, traceable, operational, and maintainable mechanism for translating information-security risks and regulatory requirements into implemented controls and auditable evidence.

The evaluation combines quantitative indicators, documentary evidence, operational control metrics, and audit results. Three complementary dimensions are considered: traceability completeness through control coverage and implementation maturity, operational effectiveness and maintainability, and external conformity.

Traceability completeness evaluates whether each applicable control is connected to all the elements defined by the proposed methodology: identified risk or requirement, organisational process, operational capability, supporting tool, retained evidence, and effectiveness indicator. This assessment determines whether the implementation can be followed from the original security requirement to the evidence used during operation and auditing. A control is considered covered when it has at least one defined organisational process or technical measure, an assigned responsible role, and identified evidence. Coverage is calculated as:

$$C_{\text{cov}} = \frac{N_{\text{covered}}}{N_{\text{applicable}}} \times 100. \tag{3}$$

where N_{covered} is the number of applicable control entries with an identified implementation mechanism and $N_{\text{applicable}}$ is the total number of applicable entries in the combined ISO/IEC 27001–ENS control register.

Additionally, implementation maturity complements control coverage by measuring the degree to which each applicable control has progressed from planning to complete and verifiable operation. It is calculated as:

$$M_{\text{impl}} = \frac{\sum_{i=1}^{N_{\text{applicable}}} s_i}{N_{\text{applicable}}} \times 100, \tag{4}$$

where s_i is the maturity score assigned to control entry i, according to the scale

$$s_i \in \{0, 0.25, 0.50, 0.75, 1.00\}.$$

A score of 0 represents an entry without an identified implementation mechanism; 0.25 represents a planned or initial implementation; 0.50 represents a partially implemented control; 0.75 represents an operational control with incomplete evidence, review, or effectiveness measurement; and 1.00 represents a fully implemented control with documented procedures, assigned responsibility, operational evidence, and an effectiveness indicator.

Operational effectiveness and maintainability assess whether the implemented controls operate as intended and can remain effective over time. This dimension considers almost all the indicators defined in Section 5.2.

External conformity is assessed using the findings of internal and external audits, including non-conformities, observations, corrective actions, and certification outcomes. ISO/IEC 27001 and ENS certification provide independent evidence that the implemented ISMS satisfies the applicable requirements within the audited scope. Nevertheless, certification is treated as evidence of conformity rather than as proof that the proposed methodology is superior to alternative implementations.

The evaluation data are obtained from the SoA, SWOT analysis, risk-treatment plan, asset inventory, documented procedures, configuration repositories, authentication and monitoring systems, Intrusion Detection Systems, incident records, backup procedures, control tests, and audit reports.

5.2. Evaluation indicators

The following operational indicators were selected according to three criteria: normative relevance, operational measurability, and relevance to the risks observed in the IFCA scientific-computing environment. Normative relevance was established from the monitoring, measurement, analysis, and evaluation principles of ISO/IEC 27004, from the metric-oriented guidance provided for the ENS in CCN-STIC-815 (CCN-CERT, 2026), and from the applicable ISO/IEC 27001-ENS controls identified in the Statement of Applicability and the combined control register.

Operational measurability required each indicator to be supported by evidence generated during normal ISMS operation, such as monitoring records, access reviews, vulnerability records, incident tickets, backup reports, restoration tests, training records, and audit findings. Finally, the indicators were adapted to the IFCA context on the basis of operational experience with heterogeneous services, federated users, externally maintained software, service availability requirements, and limited specialised personnel. Where applicable, an expected target and measurement period were defined for each indicator:

1. Availability of the required information-security policies.
2. Percentage of applicable controls with an identified implementation mechanism.
3. Availability of required documented processes and procedures to manage the complete service: security-incident and vulnerability handling, user management, backups, etc
4. Percentage of in-scope assets and services covered by centralised monitoring.
5. Percentage of in-scope accounts managed or periodically reviewed through centralised identity-management systems.
6. Mean remediation time for non-critical vulnerabilities, with a target of less than seven days.
7. Mean remediation time for critical vulnerabilities, with a target of less than 48 h.
8. Percentage of high- and critical-severity vulnerabilities remediated within their respective target periods.
9. Mean response time for information-security incidents, with a target of less than 12 h between detection or reporting and formal acknowledgement and assignment.
10. Number of information-security incidents resulting in data loss, with a target of fewer than two incidents per year.
11. Number of security incidents registered and handled through the established incident-management procedure.
12. Number of Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP) management activities completed annually, with a target of at least three activities.
13. Accumulated annual time during which the Uninterruptible Power Supply (UPS) operated in battery mode because of unplanned power events, with a target of less than two hours.
14. Accumulated annual operating time of the emergency generator caused by unplanned power-supply interruptions, with a target of less than three hours.
15. Number of security-awareness and training activities and, where available, percentage of in-scope personnel completing mandatory training.
16. Number of internal and external audit non-conformities and observations, together with their severity and resolution status.

These indicators are not combined into a single operational score because they represent different security objectives, measurement periods, and units. Only indicators supported by reliable and consistently retained records are reported quantitatively.

These indicators support the main evaluation claims of the paper: control coverage and implementation maturity are assessed through the combined control register; operational effectiveness is assessed through monitoring, vulnerability-management, incident-management, continuity, and access-management records; maintainability is assessed through policy and procedure reviews, training activities, and corrective-action tracking; and external conformity is assessed through audit findings and certification records.

5.3. Metric and evaluation results

Traceability completeness was assessed by reviewing whether each applicable control entry could be followed from its originating risk or requirement to the corresponding organisational process, operational capability, supporting mechanism, retained evidence, and effectiveness indicator. This assessment was performed using the SoA, risk-treatment plan, control register, documented procedures, and operational records.

In the risk-treatment analysis, 37 assets were initially associated with critical risks. After applying the corresponding treatment measures, this value decreased to 4 residual critical risks requiring continued monitoring or formal acceptance.

The remaining entries were considered partially traceable because one or more elements can be assumed, non-addressed, incomplete effectiveness indicators, pending procedure updates, or evidence that had not yet been collected using a consistent method.

The combined ISO/IEC 27001–ENS control register contained 126 applicable control entries. Of these, 120 had an identified implementation mechanism. The resulting control coverage was (evaluation indicator 2):

$$C_{\text{cov}} = \frac{120}{126} \times 100 = 95.2\%. \tag{5}$$

Among the 120 covered entries, 82 were assessed as fully implemented, 34 as operational but requiring additional evidence or improvement, three as partially implemented, and one as being at an initial implementation stage. The six remaining entries had no implemented mechanism at the time of the assessment.

Consequently, the overall implementation maturity was:

$$M_{\text{impl}} = \frac{82 + 0.75 * (34) + 0.50 * (3) + 0.25 * (1)}{126} \times 100 = 86.7\%. \tag{6}$$

The controls with incomplete implementation were mainly associated with recently introduced requirements, activities requiring additional organisational procedures, or processes dependent on external coordination. For example, control 5.7, Threat intelligence, required additional external guidance and the establishment of a repeatable process for collecting, analysing, and using information about information-security threats.

Operational effectiveness and maintainability were assessed using the indicators summarised in Table 3. Each indicator was evaluated against its corresponding target and measurement period using the evidence retained by the ISMS. The indicators were analysed independently because they represent different operational objectives and units of measurement.

The organisational dimension was assessed through a planned road map defined at the beginning of the year for security-awareness or training activities conducted by each member of the group during the period. The activities can be conducted through presentations to all the members of the institution, official courses or documentation of a topic to get knowledge related to some activity needed for an ISMS enhancement.

External conformity was assessed using Indicator 16 alongside the certification and surveillance records conducted since 2021. This outcome directly reflects this operational indicator and is reported as independent evidence of conformity rather than a 100% effectiveness score.

5.4. Best practices and lessons learned

The implementation of an Information Security Management System (ISMS) at IFCA has provided valuable insights into the best practices and challenges that research institutions may encounter when adopting security frameworks such as ISO/IEC 27001 and national security frameworks. Key lessons and best practices derived from our experience include:

- **Fostering a strong cybersecurity culture**: Technical controls alone are insufficient to ensure security; human factors play a critical role. Regular training, awareness campaigns, and the embedding of security best practices into the institutional culture can significantly reduce risks associated with human error.
- **Automating security processes and continuous monitoring**: Automation enhances security operations by reducing manual errors and improving efficiency. Implementing SIEMs and IDS solutions, automated vulnerability scanning, and centralised log management enables real-time threat detection and response.
- **Implementing role-based access control (RBAC) and the principle of least privilege**: Access management is fundamental to security. A robust RBAC system ensures that users have only the necessary permissions for their tasks, and adhering to the principle of least privilege minimises potential attack surfaces.
- **Aligning security policies with certification requirements**: A structured approach to security governance is essential for achieving certification. Organisations should ensure that their policies, procedures, and controls align with the requirements of ISO/IEC 27001 and relevant national frameworks. A comprehensive roadmap involving all organisational levels is vital to streamline the certification process.
- **Multidimensional risk quantification in open-source software**: Evaluating OSS through independent probability and impact matrices across 5 dimensions (security, lifecycle, dependencies, provenance, and licensing) prevents a project's maturity from masking unresolved critical vulnerabilities. Taking the maximum value rule, MAX($R_{software_residual}$), ensures critical risks are not diluted through averaging, making it possible to clearly identify where compensating controls are needed to bring residual risk down to acceptable levels.
- **Applying lifecycle governance to open-source technologies:** Open-source tools can reduce dependence on proprietary licensing models and provide greater adaptability and interoperability. However, their adoption requires the assessment of project maturity, maintenance activity, security advisories, vulnerability-response processes, documentation, available expertise, integration requirements, and replacement options. Source-code availability should therefore be regarded as an enabling characteristic rather than as a security guarantee.
- **Adopting a modular and adaptable ISMS architecture:** Separating operational capabilities and security objectives from specific software products facilitates incremental implementation and the replacement of individual components. The use of virtualisation, standard interfaces, and loosely coupled tools allows the architecture to evolve without requiring a complete redesign of the ISMS.
- **Integrating audit preparation into continual improvement:** Certification is not a one-time activity. Regular internal audits, risk assessments, and policy updates should be performed throughout the ISMS lifecycle. This approach reduces the concentration of effort immediately before external audits and supports the early identification of implementation gaps.
- **Leveraging previous management-system experience:** IFCA's previous implementation of ISO 9001 and the extension of its scope to the computing service provided useful experience in process documentation, assigned responsibilities, internal audits, corrective actions, and continual improvement. These established practices facilitated the organisational adoption of ISO/IEC 27001 and ENS requirements.

6. Challenges and future directions

Validation in additional scientific computing centres is required to determine how the methodology performs under different organisational, technical, and regulatory conditions. Future multi-site studies

Table 3
Operational effectiveness and maintainability indicators, assessment criteria, evidence sources, and evaluated results.

Operational area	Indicator	Target or assessment criterion	Evidence source	Evaluated result
Governance and documentation	1. Availability of the required information-security policies; 3. availability of required documented processes and procedures to manage the complete service.	Required policies and procedures available and reviewed within the approved review period.	Document-management system and procedure register.	16 security policies and 11 operational procedures[a].
Monitoring coverage	4. Percentage of in-scope assets and services covered by centralised monitoring.	in-scope assets and services.	Asset inventory, Icinga and Grafana configuration, Puppet, Wazuh.	700 physical and virtual assets; 100% covered (hardware, cooling system, electricity, etc.)
Identity and access management	5. Percentage of in-scope accounts managed through centralised identity-management systems.	in-scope accounts managed.	FreeIPA and Keycloak records, account inventories in RT and role assignments.	All 300 identified in-scope accounts were managed or periodically reviewed through FreeIPA or Keycloak (100%)
Vulnerability management	6. Mean remediation time for non-critical and 7. critical vulnerabilities; 8. percentage remediated within the corresponding target period.	Non-critical vulnerabilities: <7 days. Critical vulnerabilities: <48 h.	Vulnerability findings, security advisories and security tickets in RT.	Non-critical: 24–48 h; Critical: <24 h after notification.[b]
Incident management	9. Mean response time; 10. number of confirmed incidents involving data loss; 11. number of incidents handled through the established procedure	Response time: <12 h. Incidents must be classified, assigned, investigated, and closed.	Nextcloud Deck, Request Tracker tickets, alerts in IDS and Wazuh, investigation records, and closure reports.	Response: Immediate; Handled: <5 h;
Business continuity and disaster recovery	12. Number of BCP and DRP management activities	At least three DRP management activities per year and more than two successful BCP or DRP exercises per year.	Approved BCPs and DRPs, revision records, exercise reports, restoration tests.	Successful exercises: 3 (Virtual machine restoration, Disk Server removal and File recovery);
Power-supply resilience	13. Accumulated time during which the UPS operated in battery mode and 14. the emergency generator operated because of unplanned power-supply events.	UPS battery operation: <2 hs per year. generator: <3 h per year	UPS and generator logs,	UPS: 1 h; generator:2 h
Training and awareness	15. Number of security-awareness and training activities and, where available, percentage of in-scope personnel completing mandatory training.	Target established in the annual training and awareness plan.	Training activity records, course-completion reports.	Activities: Study of security advisories via mail, presentations of security guidelines in our service, study of planned courses;
Audit and corrective actions	16. Number of internal and external audit non-conformities and observations, together with their severity and resolution status.	Findings reviewed and corrective actions tracked until closure.	Internal and external audit reports; corrective-action register.	0 non-conformities; 4 observations; 100% closed within the agreed period.

[a] The security policies were available for each member and for external providers within the ISMS scope. The procedures were documented, regarding operational capability tasks: risk-treatment, requirements identification, security-incident management, backups, asset inventory, configuration change review, cryptographic protocol, networking, role assignments, component and data removal and user management.

[b] 15 vulnerabilities identified by the IDS. 95% remediated within the target period. Security incidents: 1 handled within the notification day.

should apply a common set of indicators and compare implementation effort, control coverage, traceability, operational effectiveness, maintainability, and dependence on specialised personnel.

From a technical perspective, future work will focus on strengthening the management of threat intelligence and the software supply chain through the adoption of Threat Intelligence Platforms (TIPs) (Sonwani et al., 2022) and Software Bill of Materials (SBOMs) (Sehgal and Ambili, 2024).

Threat Intelligence Platforms (TIPs) are systems designed for the management and sharing of Indicators of Compromise (IOCs) within the context of an Information Security Management System (ISMS). Their primary role is not limited to serving as static repositories of IOCs, but rather to transform heterogeneous data sources into actionable security intelligence, enriched with traceability, relationships, and contextual understanding. This capability supports the continuous improvement and operational effectiveness of an ISMS by strengthening its threat detection and response processes. Their integration with security telemetry tools (SIEMs or log management tools) (de Souza Vieira and Gondim, 2026) is a critical requirement in modern SOCs, as threat intelligence in isolation provides limited operational value.

The future integration of a TIP at IFCA will be assessed according to its interoperability, data-source support, access-control mechanisms, automation capabilities, information-sharing models, and ability to generate auditable evidence. Its contribution will be evaluated through indicators such as the number of intelligence sources integrated, indicators correlated with internal events, alerts enriched with external context, and incidents in which threat intelligence supported analysis or response.

A Software Bill of Materials (SBOMs) provides a structured inventory of the software components, libraries, dependencies, and associated metadata included in an application or computational environment. Its integration into the ISMS may improve software inventory, component provenance, vulnerability management, and dependency traceability. These tools will facilitate the identification of known vulnerabilities through databases such as the National Vulnerability Database (NVD), providing greater visibility and control over software components.

Tools such as Syft, SBOM Tool, and Trivy can generate SBOMs (Mirakhorli et al., 2024) for selected applications, containers, and software environments. However, effective use requires more than SBOM generation. The resulting records must be stored, updated, validated, associated with system and application owners, and integrated with vulnerability-management and change-management processes. The fragmented availability and uneven quality of upstream SBOMs also

remain practical challenges, particularly for complex scientific software stacks containing numerous libraries and externally maintained dependencies.

In scientific computing, SBOMs may also support reproducibility by recording the software components and versions used in a computational workflow. Nevertheless, an SBOM alone is insufficient to reproduce an experiment, since configurations, datasets, execution parameters, container or operating-system information, and provenance metadata must also be retained.

The adoption of TIPs and SBOM-based processes may support ISO/IEC 27001 and ENS compliance activities by improving threat-intelligence management, asset and software inventory, vulnerability management, traceability, and retained evidence. For example, Trivy tool can provide information about vulnerabilities in container images used in a cloud environment. However, these technologies should be regarded as supporting mechanisms rather than as compliance solutions in themselves. Their effectiveness will depend on their integration into documented processes, assigned responsibilities, periodic reviews, and measurable operational indicators.

7. Conclusions

The implementation of an Information Security Management System (ISMS) in scientific computing environments is a complex process that requires aligning policies and procedures with international standards such as ISO/IEC 27001 and the ENS. Obtaining ISO/IEC 27001 and ENS certifications has had a significant impact on the institution, allowing it to access new funding opportunities and improving IT security management. Furthermore, it has optimised the work of the IT team, reducing human errors and shortening staff training times thanks to the structured documentation of procedures and controls.

This work has presented an implementation methodology and a real-world reference case for a predominantly open-source-based ISMS at a real-world case study. The proposed approach establishes traceability between identified risks and requirements, applicable controls, organisational processes, operational capabilities, responsible roles, supporting technologies, audit evidence, and effectiveness indicators. This mapping helps prevent compliance from being reduced to the deployment of individual software products and shows that the effectiveness of a control depends on the combined operation of governance, procedures, personnel, and technical measures.

Control maturity was assessed exclusively through internal and third-party audits using verifiable operational evidence rather than self-reporting. Of the 126 framework entries, 120 were operationalised — achieving 95.2% control coverage and an estimated maturity of 86.7% — while the remaining six were formally excluded from the Statement of Applicability (SoA) under explicit scope justifications. Official ISO/IEC 27001 and ENS certifications, coupled with ongoing surveillance audits, provide independent validation of conformity within the evaluated infrastructure.

This work highlights the main challenges in computing security and in scientific environments mainly focused on the use of open-source software. Open-source tools in security environments pose additional challenges, such as the need to constantly assess their maintenance and support. It has been observed that the combination of multiple tools and the implementation of redundancy strategies can mitigate potential individual limitations.

The IFCA case study demonstrates that open-source technologies can support a substantial part of the operational capabilities required by an ISO/IEC 27001 and ENS aligned ISMS, including identity and access management, configuration control, monitoring, log management, vulnerability management, backup, incident handling, and documentation. Their main advantages are adaptability, interoperability, access to the source code, and reduced dependence on proprietary licensing models. These benefits, however, are conditional on the operational fit of each component and on the availability of specialised personnel; the cost-effectiveness of an open-source-based ISMS therefore depends on the organisational context rather than on the licensing model alone.

The successful certification of the defined scope provides independent evidence that the implemented ISMS satisfied the applicable ISO/IEC 27001 and ENS requirements at the time of assessment. Nevertheless, certification should be interpreted as evidence of conformity within a specific organisational and technical scope, rather than as proof of the superiority of the selected tools or of the universal transferability of the methodology.

Beyond the technical aspects, the experience also confirms the importance of fostering a cybersecurity culture within scientific institutions. Security not only depends on tools and regulations but also on the awareness and continuous training of personnel. Without institutional commitment and adequate training, even the best tools may be insufficient to mitigate risks. This experience demonstrates the practical value of implementing robust security practices to ensure a secure scientific computing infrastructure.

Finally, it is recommended that the scientific community continue to promote the development and adoption of open-source security software. Collaboration between institutions, the exchange of best practices, and the creation of open standards can significantly strengthen security in scientific computing.

CRediT authorship contribution statement

Jose Ibán Cabrillo Bartolomé: Writing – review & editing, Writing – original draft, Resources, Methodology, Investigation, Conceptualization. **Miguel Ángel Nuñez Vega:** Writing – review & editing, Writing – original draft, Validation, Methodology, Investigation, Conceptualization. **Aida Palacio Hoz:** Writing – review & editing, Writing – original draft, Resources, Methodology, Investigation, Conceptualization.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgements

The authors would like to thank the members of the Advanced Computing and E-Science group at IFCA for the revision and the ideas discussed for completing this work.

Data availability

No data was used for the research described in the article.

References

Amiruddin, A., Afiansyah, H.G., Nugroho, H.A., 2021. Cyber-risk management planning using NIST CSF v1.1, NIST SP 800-53 rev. 5, and CIS controls v8. In: 2021 International Conference on Informatics, Multimedia, Cyber and Information System. ICIMCIS, pp. 19–24. http://dx.doi.org/10.1109/ICIMCIS53775.2021.9699337.

Ansible, 2026. Ansible collaborative. URL: https://www.ansible.com/. (Accessed 21 April 2026).

Antunes, B., Hill, D.R., 2024. Reproducibility, replicability and repeatability: A survey of reproducible research with a focus on high performance computing. Comput. Sci. Rev. 53, 100655. http://dx.doi.org/10.1016/j.cosrev.2024.100655, URL: https://www.sciencedirect.com/science/article/pii/S157401372400039X.

Apache CloudStack, 2026. Apache Software Foundation. URL: https://cloudstack.apache.org/. (Accessed 21 April 2026).

Bacula, 2026. Bacula - The Open source backup software for Linux. URL: https://www.bacula.org/. (Accessed 21 April 2026).

Barba, L.A., 2022. Defining the role of open source software in research reproducibility. Computer 55 (8), 40–48. http://dx.doi.org/10.1109/MC.2022.3177133.

CCN-CERT, 2026. 800 ENS guidelines. URL: https://www.ccn-cert.cni.es/es/800-guia-esquema-nacional-de-seguridad/. (Accessed 14 September 2026).

Centro Criptológico Nacional, 2023. CCN-STIC 825: Mapeo Entre La Norma ISO/IEC 27001:2022 Y El Real Decreto 311/2022 (ENS). Technical Report CCN-STIC 825, Centro Criptológico Nacional, CCN-CERT, Madrid, Spain, https://www.ccn-cert.cni.es/es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad.html. Independent annex.

Chierici, A., de Girolamo, D., Guizzunti, G., Longo, S., Maron, G., Martelli, B., Vistoli, C., Zani, S., Castellani, G., Giampieri, E., 2019. SGSI project at CNAF. EPJ Web Conf. 214, 08017. http://dx.doi.org/10.1051/epjconf/201921408017.

Cisco Umbrella, 2026. Cisco Umbrella - DNS and Cloud Cybersecurity Solutions. URL: https://umbrella.cisco.com/. (Accessed 21 April 2026).

de Souza Vieira, A.A., Gondim, J.J.C., 2026. Methodology for threat detection and prevention integrating cyber threat intelligence and SIEM. In: Rocha, A., Adeli, H., Poniszewska-Marańda, A., Moreira, F., Bianchi, I. (Eds.), Emerging Trends in Information Systems and Technologies. Springer Nature Switzerland, Cham, pp. 95–107.

Diskin, M., Bukhtiyarov, A., Ryabinin, M., Saulnier, L., Lhoest, Q., Sinitsin, A., Popov, D., Pyrkin, D.V., Kashirin, M., Borzunov, A., del Moral, A.V., Mazur, D., Kobelev, I., Jernite, Y., Wolf, T., Pekhimenko, G., 2021. Distributed deep learning in open collaborations. CoRR abs/2106.10207. arXiv:2106.10207. URL: https://arxiv.org/abs/2106.10207.

EGI, 2026. EGI: Advanced Computing for a Data-Driven Future. URL: https://www.egi.eu/. (Accessed 20 April 2026).

EOSC, 2026. European open science cloud - advancing open science in Europe. URL: https://eosc.eu/. (Accessed 21 April 2026).

European Union, 2026. NIS 2. URL: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:3A32022L2555&qid=1723630548361. (Accessed 21 April 2026).

Fabre, R., Egret, D., Schöpfel, J., Azeroual, O., 2021. Evaluating the scientific impact of research infrastructures: The role of current research information systems. Quant. Sci. Stud. 2 (1), 42–64. http://dx.doi.org/10.1162/qss_a_00111.

Fecher, B., Kahn, R., Sokolovska, N., Völker, T., Nebe, P., 2021. Making a research infrastructure: Conditions and strategies to transform a service into an infrastructure. Sci. Public Policy 48 (42), 499–507. http://dx.doi.org/10.1093/scipol/scab026.

FreeIPA, 2026. FreeIPA - identity, policy, audit. URL: https://www.freeipa.org/page/Main_Page. (Accessed 21 April 2026).

Gerrit, 2026. Gerrit code review. URL: https://www.gerritcodereview.com/. (Accessed 20 April 2026).

Giordano, D., Alef, M., Atzori, L., Barbet, J.-M., Datskova, O., Girone, M., Hollowell, C., Javurkova, M., Maganza, R., Medeiros, M., Michelotto, M., Rinaldi, L., Sciabà, A., Sobie, R., Southwick, D., Sullivan, T., Valassi, A., 2021. HEPiX benchmarking solution for WLCG computing resources. Comput. Softw. Big Sci. 5, http://dx.doi.org/10.1007/s41781-021-00074-y.

GitLab, 2026. GitLab - Open source software to collaborate on code. URL: https://about.gitlab.com/install/#install-self-managed-gitlab. (Accessed 21 April 2026).

Government of Spain, 2022. Real decreto 311/2022, de 3 de mayo, por el que se regula el esquema nacional de seguridad. URL: https://www.boe.es/eli/es/rd/2022/05/03/311/con. Published 4 May 2022. Boletín Oficial del Estado, no. 106, BOE-A-2022-7191.

Grafana, 2026. Grafana labs - open and composable observability and data visualization platform. URL: https://grafana.com/. (Accessed 21 April 2026).

Grafana Loki, 2026. Grafana labs. URL: https://grafana.com/docs/loki/latest/. (Accessed 03 July 2026).

Gun, A., Garg, T., 2024. Prerequisite for reproducible science: a call to embrace code sharing. Lancet Reg. Health Southeast Asia 29, 100472. http://dx.doi.org/10.1016/j.lansea.2024.100472, URL: https://www.sciencedirect.com/science/article/pii/S2772368224001227.

Guo, C., Chen, J., 2023. Big data analytics in healthcare. In: Knowledge Technology and Systems: Toward Establishing Knowledge Systems Science. Springer Nature Singapore, Singapore, pp. 27–70. http://dx.doi.org/10.1007/978-981-99-1075-5_2.

Hasibovic, A.C., Tanovic, A., 2024. Review of ISO 9001:2015 and ISO 27001:2013 implementation in financial institution – case study. In: 2024 47th MIPRO ICT and Electronics Convention. MIPRO, pp. 1520–1525. http://dx.doi.org/10.1109/MIPRO60963.2024.10569415.

Haufe, K., Colomo-Palacios, R., Dzombeta, S., Brandis, K., Stantchev, V., 2016. Security management standards: A mapping. Procedia Comput. Sci. 100, 755–761. http://dx.doi.org/10.1016/j.procs.2016.09.221, URL: https://www.sciencedirect.com/science/article/pii/S1877050916323900. International Conference on ENTERprise Information Systems/International Conference on Project MANagement/International Conference on Health and Social Care Information Systems and Technologies, CENTERIS/ProjMAN / HCist 2016.

IBM, 2026. Cost of a data breach report 2025. URL: https://www.ibm.com/reports/data-breach. (Accessed 10 April 2026).

Icinga, 2026. Icinga community: Monitor your entire infrastructure with Icinga. URL: https://icinga.com/docs/icinga-2/latest/doc/01-about/. (Accessed 21 April 2026).

International Organization for Standardization, 2015. Quality Management Systems – Requirements. Standard ISO 9001:2015, ISO, Geneva, Switzerland.

International Organization for Standardization, International Electrotechnical Commission, 2022. Information Security, Cybersecurity and Privacy Protection—Information Security Management Systems—Requirements, Technical Report ISO/IEC 27001:2022, third ed. ISO/IEC, Geneva, Switzerland, URL: https://www.iso.org/standard/27001.html.

IPCC, 2023. Climate Change 2021 – The Physical Science Basis: Working Group I Contribution to the Sixth Assessment Report of the Intergovernmental Panel on Climate Change, first ed. Cambridge University Press, http://dx.doi.org/10.1017/9781009157896, URL: https://www.cambridge.org/core/product/identifier/9781009157896/type/book.

Jenkins, 2026. The linux foundation. URL: https://www.jenkins.io/. (Accessed 20 April 2026).

Keycloak, 2026. Keycloak - Open Source Identity and Access Management. URL: https://www.keycloak.org/. (Accessed 21 April 2026).

Lear, M.K., Spata, A., Tittler, M., Fishbein, J.N., Arch, J.J., Luoma, J.B., 2023. Transparency and reproducibility in the journal of contextual behavioral science: An audit study. J. Context. Behav. Sci. 28, 207–214. http://dx.doi.org/10.1016/j.jcbs.2023.03.017, URL: https://www.sciencedirect.com/science/article/pii/S2212144723000406.

MAAS, 2026. MAAS - bare metal and data center automation tool. URL: https://canonical.com/maas. (Accessed 21 April 2026).

Mario, B., Kilty, J., 2024. A right to know? Using access to information as method in critical criminological research. Qual. Inq. 10778004241256140. http://dx.doi.org/10.1177/10778004241256140, arXiv:https://doi.org/10.1177/10778004241256140.

MAT2, 2026. Metadata removal tool. URL: https://github.com/tpet/mat2. (Accessed 07 July 2026).

Mateescu, G., Gentzsch, W., Ribbens, C.J., 2011. Hybrid computing—Where HPC meets grid and cloud computing. Future Gener. Comput. Syst. 27 (5), 440–453. http://dx.doi.org/10.1016/j.future.2010.11.003, URL: https://www.sciencedirect.com/science/article/pii/S0167739X1000213X.

Mattermost, 2026. Mattermost, inc. URL: https://mattermost.com/. (Accessed 21 April 2026).

Mera-Amores, F., Roa, H.N., 2024. Enhancing information security management in small and medium enterprises (SMEs) through ISO 27001 compliance. In: Arai, K. (Ed.), Advances in Information and Communication. Springer Nature Switzerland, Cham, pp. 197–207.

Mirakhorli, M., Garcia, D., Dillon, S., Laporte, K., Morrison, M., Lu, H., Koscinski, V., Enoch, C., 2024. A landscape study of open source and proprietary tools for software bill of materials (SBOM). URL: https://arxiv.org/abs/2402.11151. arXiv:2402.11151.

Moses, F., Sandkuhl, K., 2023. ISMS in small public sector organisations: Requirements and design of a procedural approach. In: Joint Proceedings of the BIR 2023 Workshops and Doctoral Consortium. In: CEUR Workshop Proceedings, vol. 3514, CEUR-WS.org, Ascoli Piceno, Italy, pp. 1–10, URL: https://ceur-ws.org/Vol-3514/short60.pdf.

Nextcloud, 2026. Nextcloud Project- open source content collaboration platform. URL: https://nextcloud.com/. (Accessed 20 April 2026).

Nwipe, 2026. Nwipe - secure disk eraser. URL: https://github.com/martijnvanbrummelen/nwipe. (Accessed 21 April 2026).

OpenNebula, 2026. OpenNebula systems- open source cloud & edge computing platform. URL: https://opennebula.io. (Accessed 21 April 2026).

OpenStack Project, 2026. OpenStack open source cloud computing infrastructure. URL: https://openstack.org/. (Accessed 21 April 2026).

OpenTofu, 2026. Mozilla public license v2.0. URL: https://opentofu.org/. (Accessed 03 July 2026).

Outline, 2026. General outline, inc. - Your team's knowledge base. URL: https://www.getoutline.com/. (Accessed 21 April 2026).

Pianosi, F., Sarrazin, F., Wagener, T., 2020. How successfully is open-source research software adopted? Results and implications of surveying the users of a sensitivity analysis toolbox. Environ. Model. Softw. 124, 104579. http://dx.doi.org/10.1016/j.envsoft.2019.104579, URL: https://www.sciencedirect.com/science/article/pii/S136481521930619X.

Podrecca, M., Culot, G., Nassimbeni, G., Sartor, M., 2022. Information security and value creation: The performance implications of ISO/IEC 27001. Comput. Ind. 142, 103744. http://dx.doi.org/10.1016/j.compind.2022.103744, URL: https://www.sciencedirect.com/science/article/pii/S0166361522001415.

Pujol Priego, L., Wareham, J., 2023. From bits to atoms: Open source hardware at CERN. MIS Q.: Manag. Inf. Syst. 47 (2), 639–668. http://dx.doi.org/10.25300/MISQ/2022/16733, Publisher Copyright: ©2023. The Authors.

Puppet, 2026. Perforce software. URL: https://www.puppet.com/community/open-source/open-source-puppet. (Accessed 20 April 2026).

Rajak, C., Bharti, J., Mateen, A., Mehndiratta, N., Chauhan, J., Marndi, R., 2023. A roadmap to ISMS ISO 27001 implementation process. In: 2023 3rd International Conference on Range Technology. ICORT, IEEE, pp. 1–5. http://dx.doi.org/10.1109/ICORT56052.2023.10249115.

Request Tracker, 2026. Request tracker - open source, enterprise-grade issue and ticket tracking system. URL: https://requesttracker.com/. (Accessed 21 April 2026).

Rodríguez-Mejías, S., Degli-Esposti, S., González-García, S., Parra-Calderón, C.L., 2024. Toward the European health data space: The IMPaCT-data secure infrastructure for EHR-based precision medicine research. J. Biomed. Inform. 156, 104670. http://dx.doi.org/10.1016/j.jbi.2024.104670, URL: https://www.sciencedirect.com/science/article/pii/S1532046424000881.

Security Onion, 2024. Security Onion Solutions - free and open platform for threat hunting, enterprise security monitoring, and log management. URL: https://securityonionsolutions.com/. (Accessed 26 September 2024).

Sehgal, V., Ambili, P., 2024. A taxonomy and survey of software bill of materials (SBOM) generation approaches. Commun. Comput. Inf. Sci. 40–51. http://dx.doi.org/10.1007/978-3-031-50815-8_3.

Shojaei, P., Vlahu-Gjorgievska, E., Chow, Y.-W., 2024. Security and privacy of technologies in health information systems: A systematic literature review. Computers 13 (2), http://dx.doi.org/10.3390/computers13020041, URL: https://www.mdpi.com/2073-431X/13/2/41.

Sonwani, H., Divya, M., Dhawan, A., Mantri, A., G, D., Kumar, H., 2022. A comprehensive study on threat intelligence platform. In: 2022 International Conference on Communication, Computing and Internet of Things. IC3IoT, pp. 1–5. http://dx.doi.org/10.1109/IC3IOT53935.2022.9767985.

Sussy, B., Wilber, C., Milagros, L., Carlos, M., 2015. ISO/IEC 27001 implementation in public organizations: A case study. In: 2015 10th Iberian Conference on Information Systems and Technologies. CISTI, pp. 1–6. http://dx.doi.org/10.1109/CISTI.2015.7170355.

Thakur, A.M., Milewicz, R., Jahanshahi, M., Paganini, L., Vasilescu, B., Mockus, A., 2025. Scientific open-source software is less likely to become abandoned than one might think! lessons from curating a catalog of maintained scientific software. Proc. ACM Softw. Eng. 2 (FSE), http://dx.doi.org/10.1145/3729369.

Tsipouri, L., Liarti, S., Vignetti, S., Martins Grapengiesser, I., 2025. The economic impact of open science: a scoping review. R. Soc. Open Sci. 12 (9), 250754. http://dx.doi.org/10.1098/rsos.250754.

Vielberth, M., Böhm, F., Fichtinger, I., Pernul, G., 2020. Security operations center: A systematic study and open challenges. IEEE Access 8, 227756–227779. http://dx.doi.org/10.1109/ACCESS.2020.3045514.

Wazuh, 2026. Wazuh, inc. URL: https://wazuh.com/. (Accessed 21 April 2026).

Worldwide LHC Computing Grid (WLCG), 2026. Worldwide LHC computing grid (WLCG). URL: https://wlcg.web.cern.ch/. (Accessed 20 April 2026).

Zimbra, 2026. Zimbra - synacor, inc. - Deploy email and collaboration. URL: https://www.zimbra.com/product/download/. (Accessed 21 April 2026).